

GRC CASE STUDY

Falcon Freight Solutions – Governance, Risk & Compliance Audit

1. Company Overview

Falcon Freight Solutions is a mid-sized logistics and supply chain company established in 2018, with headquarters in Johannesburg, South Africa. The company operates across Southern and East Africa, providing services such as freight forwarding, warehouse management, customs clearance, and last-mile delivery.

Falcon Freight uses a hybrid IT infrastructure consisting of:

- A cloud-based shipment tracking platform
- An on-premise warehouse management system
- Third-party vendors including customs brokers and delivery contractors

As the company has expanded into multiple regions, it has onboarded several external partners and vendors, increasing its operational complexity and exposure to risk.

2. Business Problem

Falcon Freight Solutions is experiencing rapid growth; however, its governance and compliance processes have not scaled accordingly.

Key challenges include:

- Lack of standardized policies across regional offices
- Inconsistent vendor onboarding and risk assessment processes
- Uncontrolled third-party access to sensitive customer and shipment data
- Limited visibility into compliance obligations across jurisdictions
- Absence of a formal risk management framework

Due to these issues, Falcon Freight is unable to demonstrate compliance with regulatory requirements and industry standards, putting client contracts and business reputation at risk.

3. Your Role

You have been hired as a **GRC Analyst Consultant** to evaluate Falcon Freight's current governance structure and risk posture.

Your responsibilities include:

- Conducting a comprehensive risk assessment
- Identifying governance and compliance gaps
- Assessing third-party/vendor risks
- Recommending a standardized GRC framework
- Delivering an audit-ready compliance report

4. Objectives of the Assessment

The primary objectives of this case study are to:

- Identify risks affecting data security, operations, and regulatory compliance
- Evaluate existing controls and highlight weaknesses
- Align the organisation with recognised frameworks and standards
- Develop a structured and scalable GRC framework
- Improve trust with clients, regulators, and stakeholders

5. Applicable Frameworks and Regulations

The assessment will be aligned with the following frameworks:

- **ISO/IEC 27001:2022** – Information Security Management
- **ISO 31000** – Risk Management
- **NIST Cybersecurity Framework (CSF)** – Security controls and best practices
- **GDPR** – Data protection and privacy (for international data handling)

6. Key Risk Areas

The following critical risk areas have been identified:

- **Data Protection Risk**
Exposure of customer and shipment data due to weak access controls
- **Third-Party Risk**
Vendors and subcontractors accessing systems without proper security validation
- **Compliance Risk**
Failure to meet regulatory and contractual requirements
- **Operational Risk**
Inconsistent processes across regional offices
- **Cybersecurity Risk**
Vulnerabilities in cloud systems and internal infrastructure

7. Project Approach

The GRC assessment will follow a structured approach:

1. **Discovery & Scoping**
Understand business operations, systems, and vendor relationships
2. **Compliance Gap Analysis**
Identify missing or weak policies and controls
3. **Risk Assessment**
Evaluate likelihood and impact of identified risks
4. **Framework Mapping**
Align findings with ISO 27001, NIST CSF, and ISO 31000
5. **Recommendations & Reporting**
Provide actionable solutions and a compliance roadmap

8. Expected Outcomes

At the end of this project, Falcon Freight Solutions will:

- Have a clearly defined GRC framework
- Understand its key risks and mitigation strategies
- Improve compliance readiness
- Strengthen vendor governance
- Enhance overall security posture

9. Conclusion

Falcon Freight Solutions must transition from informal and inconsistent practices to a structured, standardised GRC framework. By implementing recognised frameworks such as ISO 27001 and NIST CSF, the organisation can reduce risk exposure, ensure regulatory compliance, and build long-term trust with clients and stakeholders.